CyBOK

Incident management and response
Tool and trix of the trade

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

Litterature note

- This lecture is based on the following CyBOK knowledge areas:
  - Security Sperations and Incident Management

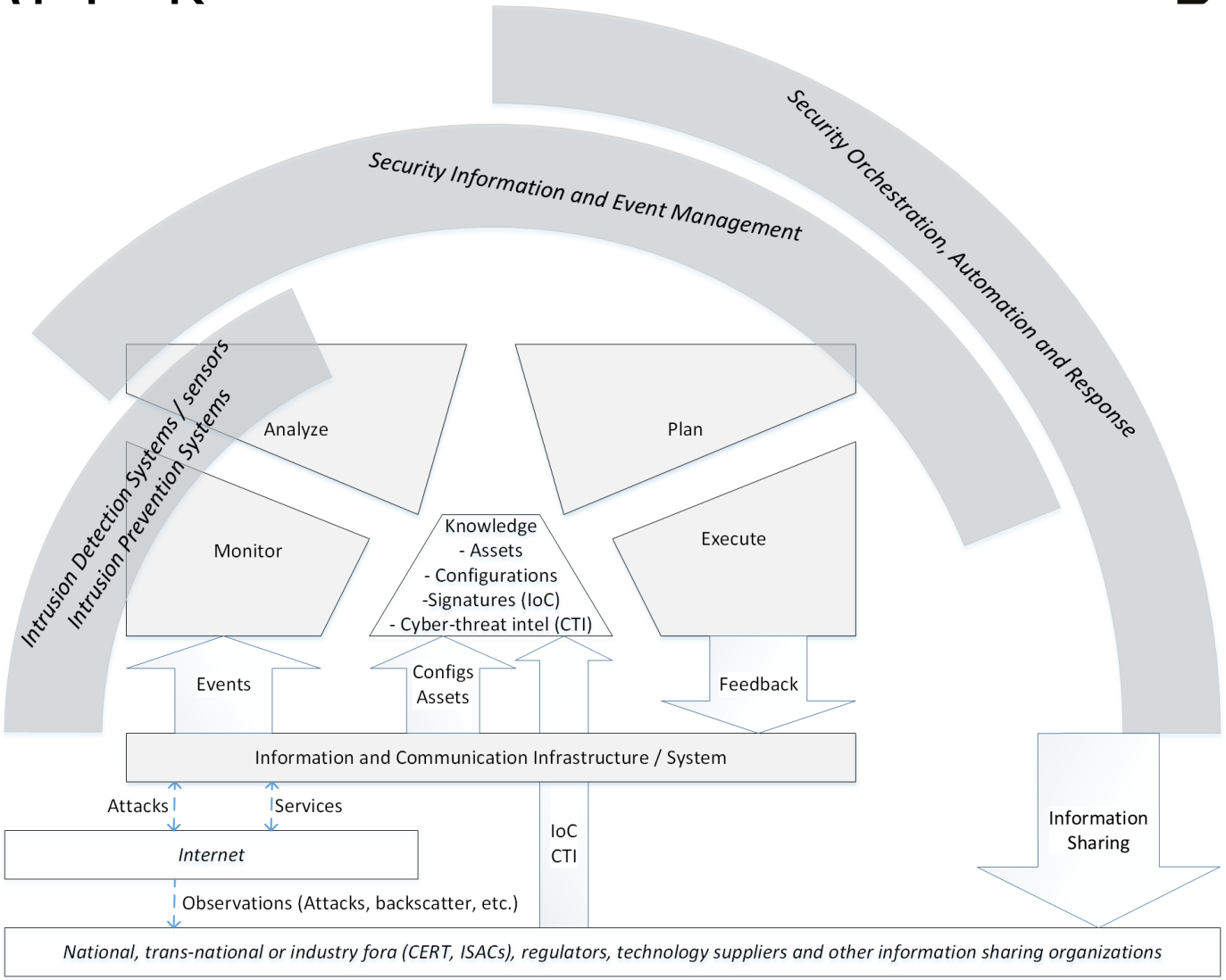
- Additional material is cited throughout the lecture

Agenda

- Continuing the MAPE-K discussion
  - Monitor
  - Analyze
  - Plan
  - Execute

- Technologies for the different steps

SOIM – MAPF-K

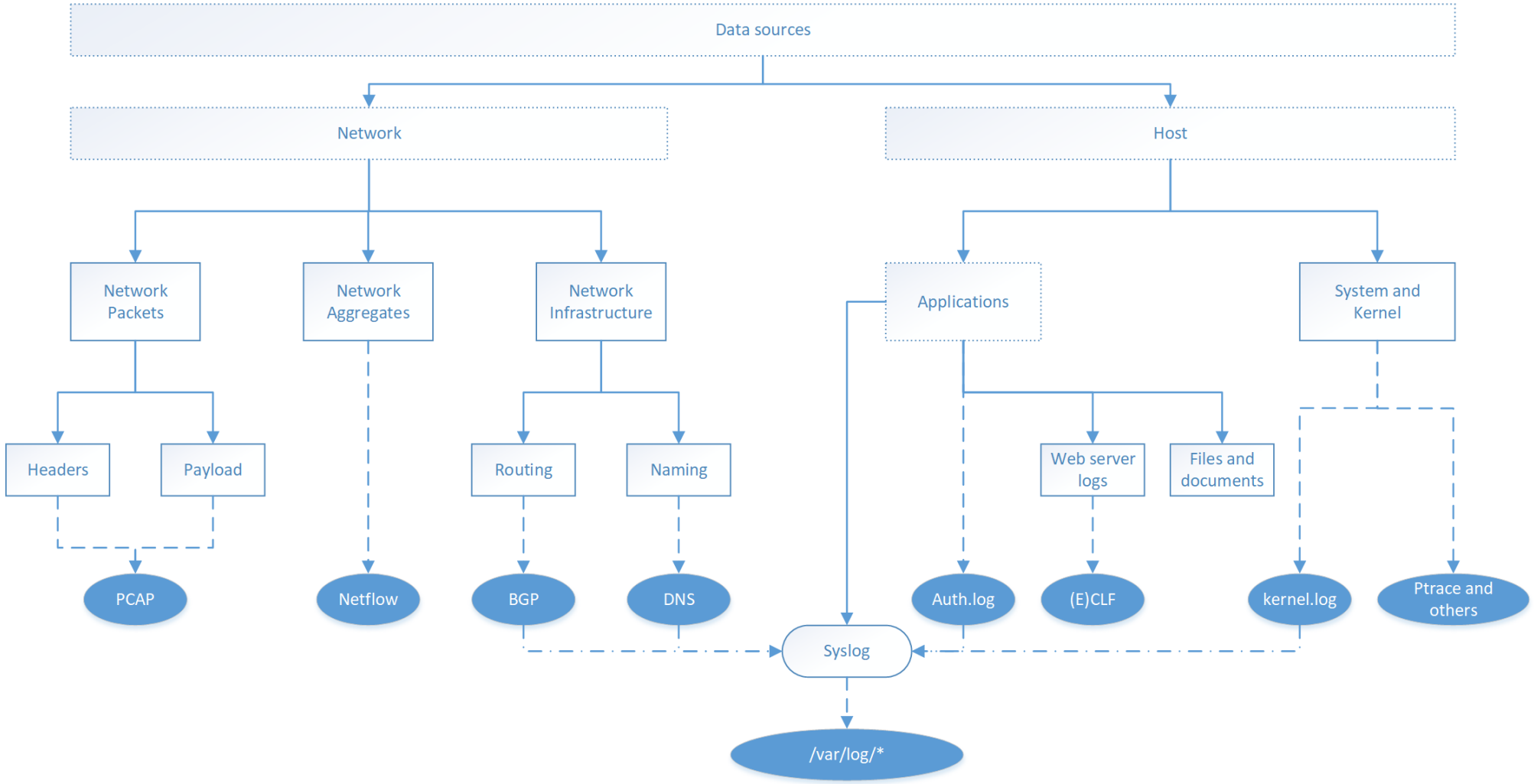

Security Orchestration, Automation and Response
Security Information and Event Management
Intrusion Detection Systems / sensors
Intrusion Prevention Systems
Analyze
Plan
Monitor
Knowledge
- Assets
- Configurations
-Signatures (IoC)
- Cyber-threat intel (CTI)
Execute
Events
Configs
Assets
Feedback
Information and Communication Infrastructure / System
Attacks
Services
Internet
IoC
CTI
Information
Sharing
Observations (Attacks, backscatter, etc.)
National, trans-national or industry fora (CERT, ISACs), regulators, technology suppliers and other information sharing organizations

Monitor

- Collection of information about the operation or hosts and networks

- Includes data from sensor devices, other security devices, network equipment and end-hosts
  - IDPS
  - Firewalls
  - Clients
  - Servers
  - …..

Monitor


Data sources
Network
Host
Network Packets
Network Aggregates
Network Infrastructure
Applications
System and Kernel
Headers
Payload
Routing
Naming
Web server logs
Files and documents
PCAP
Netflow
BGP
DNS
Auth.log
(E)CLF
kernel.log
Ptrace and others
Syslog
/var/log/*

Monitor - Snort

- One of the most commonly used IDPS systems
- Network-based IDPS
- Open-source and maintained by the community and the Cisco Talos team

Monitor - Snort

CyBOK

- Snort is a rule-based system
  - You define what is benign or harmful using rules
  - Alerts are sent when harmful data is identified

- Different modes of operation
  - Sniffer: dumps packets in transit
  - Packet logger: Logs packets in transit (i.e. stores them to disk)
  - IDPS: blocks or permits traffic based on rules
  - PCAP investigation: Use rules to investigate PCAP files

Monitor – Snort rules

- Snort is mainly configured from the file */etc/snort.conf*
  - Rules are typically maintained in rule files which are included from the *snort.conf*

- You can write your own rules or download rule-sets from snorts web page

- We will explore snort modes and rules in the labs

Monitor

CyBOK

- Handling logs from all those sources can be challenging indeed

- It is typical to have a system that aggregates log data from all different sources
  - SIEM (Security Information and Event Management), which focuses on security data
  - Dedicated log aggregation system such as syslog for other data
  - (Those can be the same tool)

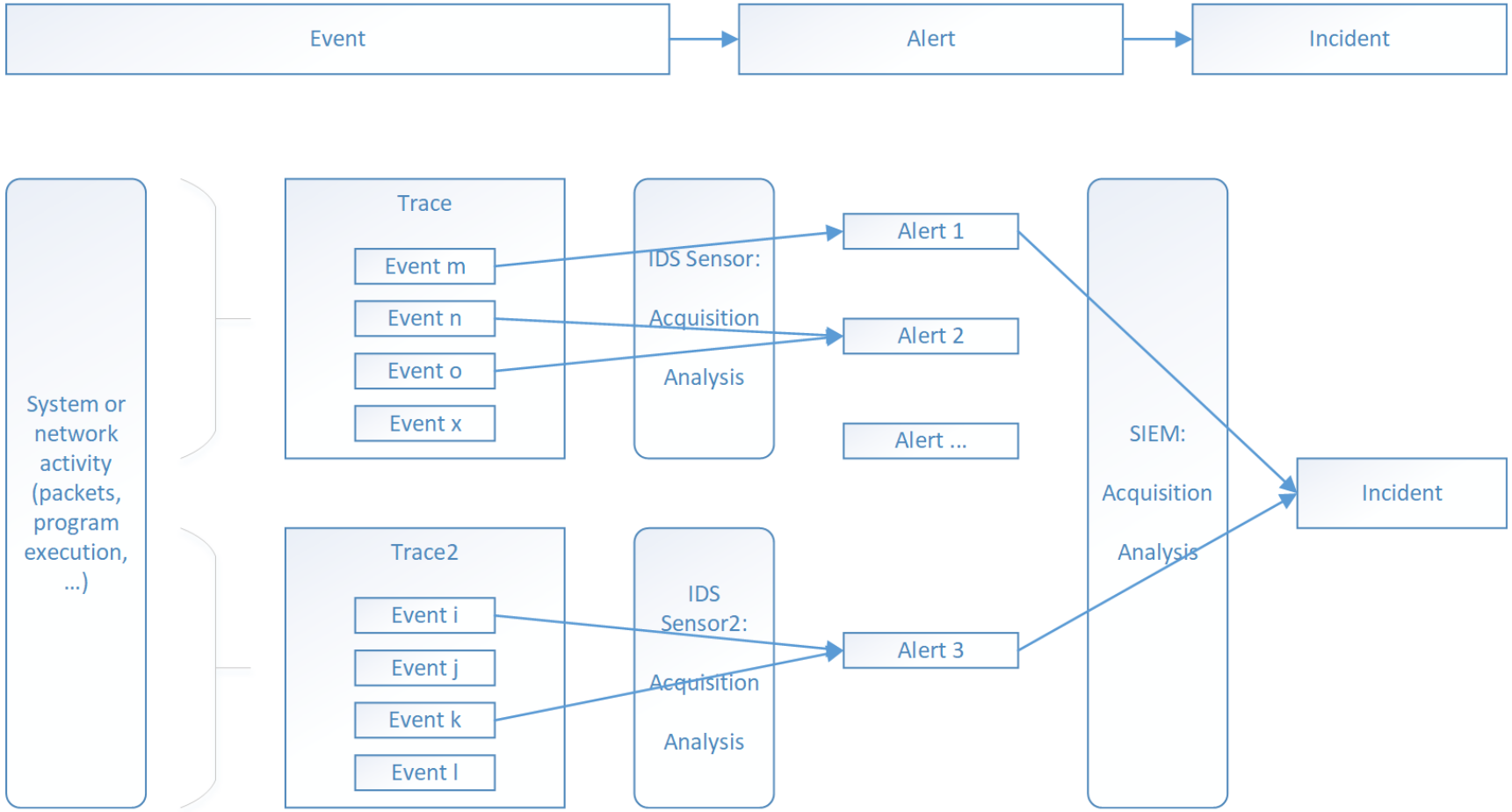
REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Analyze

- All the data we collect needs to be analyzed
- With all the data that we often gather, a stringent approach is needed to make sense of that data
- This is where the SIEM comes into play
  - ELK/Elastic stack
  - Splunk
  - …..

Analyze


Event
Alert
Incident
System or network activity (packets, program execution, ...)
Trace
Event m
Event n
Event o
Event x
Trace2
Event i
Event j
Event k
Event l
IDS Sensor:
Acquisition
Analysis
IDS Sensor2:
Acquisition
Analysis
Alert 1
Alert 2
Alert ...
Alert 3
SIEM:
Acquisition
Analysis
Incident

Analyze – misuse detection

- There are two broad methods for data analysis
  - Misuse detection
  - Anomaly detection

- Misuse detection relies on definitions of harmful code/behaviour/traffic…
  - Signatures
  - IoC

Analyze – misuse detection

- From a technical perspective, a misuse detection tool will match signature of bad, and report when a hit is found
- Misuse detection is comparably cheap, and easy to implement
- A downside is difficulty to identifying new events

Analyze – Anomly detection

- Anomaly detection is essentially about finding deviations from normal system operations
- Builds on the theory that an incident is an anomaly
- Used in both SIEMs and IDPS systems

Analyze – Anomly detection

- Anomaly detection relies on models (often statistical) that define normal and anomalous behavior
- Events will be given a score that reflect how normal they are
- A threshold for when an alarm is raised must be decided upon

Analyze – Anomly detection

- Depending on the threshold, we will get more or less false positives or false negatives
  - False positive: Alert is raised for benign event
  - False negative: Alert is not raised for malicious event
  - True positive: Alert is raised for malicious even
  - True negative: Alert is not raised for benign event

- Less false positives typically means less true positives

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Planning

CyBOK

- The planning phase is, with the analyze phase, covered by the SIEM.
- The SIEM aggregates information from the monitor and analyze phases
  - Connection
  - Correlation
  - Correlation with CTI
- The ideal output is a list of incidents that an analyst needs to handle

Planning – ELK at a glance

- The ELK stack (now Elastic stack) is a combination of four technologies
  - Elasticserach
  - Logstach
  - Kibana
  - Beats

- Logstack is a log agrregator which collects logs from various sources

Planning – ELK at a glance

- Elasticserach is a search engine
- Kibana is a visualization layer for elastichserach which makes it possible to create various dashboards
- Beats are agrnets that can collect data from hosts and forward to elasticserach
- The components can be used as a SIEM

Planning – Splunk at a glance

- SPLUNK is an enterprise set of tools capable of providing SIEM functionality
- SPLUNK can process data from many different sources and provide aggregation and search functionality
- The labs will go over both ELK and SPLUNK

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Execute

- The response to a detected incidents
- Highly situational, different events require different responses
- Can be partly automated but more complex incidents require human intervention

Execute - automated

- To quite a large extent, mitigations are actually automated
  - IDPS block rules
  - Firewall filters
  - Malware quarantine
  - …..
- When mitigations can't be automated, the Security Operations Center (SOC) takes over

Execute - SOC

CyBOK

- NIST SP 800-53, Rev 5 describes a SOC as "*the focal point for security operations and computer network defense for an organization*"
- Core task is to detect, analyze, and respond to incidents in a timely manner
  - Also includes preparation and handling of relevant tools for the task
- A SOC can sometimes also handle security infrastructure

Execute – SOC roles

CyBOK

- A SOC manager leads the SOC and typically reports to the CEO or CISO
- Security engineers evaluate, implement, and maintain security technologies (tools)
- Security analysts (incident responders) analyze threats and incidents (and alarms)
- Threat hunters are tasked with finding threats and vulnerabilities before they are exploited by hackers

Execute - playbooks

CyBOK

- Incidents are diverse, and it can be hard to always figure out the best course of action swiftly
- Also, many incidents are quite frequently occurring
- To help manage incidents efficiently, playbooks are used

Execute - playbooks

CyBOK

- A playbook is basically a guide of how to handle a certain incident type

- Playbooks can be developed as part of the incident response policy development
  - Should be refined after they are used
  - New playbooks defined upon discovery of new incidents
  - General playbooks can be downloaded form internet and adapted as needed

Execute - playbooks

CyBOK

- The exact content of a playbook is of course up to the organization, but it typically includes
  - Roles to be involved in the handling of an incident
    - Staff roles
    - Technical roles (i.e. user accounts) and permissions
  - Tools to use
  - Steps to take

- Some public examples from Microsoft
  - https://learn.microsoft.com/en-us/security/operations/incident-response-playbook-phishing

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Thank you for today!